

API gateway: govern business requests

API gateway → AI gateway → MCP gateway
Then investigate and repair Flo Bank.

04

150
MINUTES

15-minute gateway primer + 135-minute incident-response lab

How an API gateway works

01

Client

Send method, path
and credential



02

Gateway

Match route; apply
configured controls



03

Service

Enforce business
authorization



04

Response

Return result;
record telemetry

A successful HTTP response establishes delivery, not business legitimacy.

API gateway capabilities

ACCESS

Authentication, routing and request-rate controls.

RELIABILITY

Upstream balancing, timeouts and configured retries.

VISIBILITY

Request logs, metrics and distributed trace integration.

For financial writes, retries require a stable business idempotency key.

AI gateway: manage model consumption

MODEL ACCESS

A governed entry point for configured model providers.

CONSUMPTION

Token limits, output limits and inference allowance.

OPERATIONS

Configured routing, resilience and model-traffic telemetry.

In this lab, an adapter reserves the inference allowance before dispatch.

How the AI gateway evaluates a request

01

Receive

Messages +
requested output



02

Reserve

Estimate input;
reserve output



03

Dispatch

Call provider only if
allowed



04

Reconcile

Update allowance
using actual usage

Reject projected overuse before making the provider call.

MCP gateway: expose governed capabilities

Concern	Interface	Enforcement
Discover	tools/list returns named tools	Expose the intended capability surface
Invoke	tools/call carries arguments	Validate caller, tool and arguments
Execute	Call a downstream API	Preserve downstream authorization

Tool discovery is useful; authorization must hold at invocation.

How the MCP gateway handles a payment

01

Agent

Select
create_payment



02

MCP boundary

Read identity and
actual arguments



03

OPA

Allow, deny or
require approval



04

API boundary

Authorize the
business operation

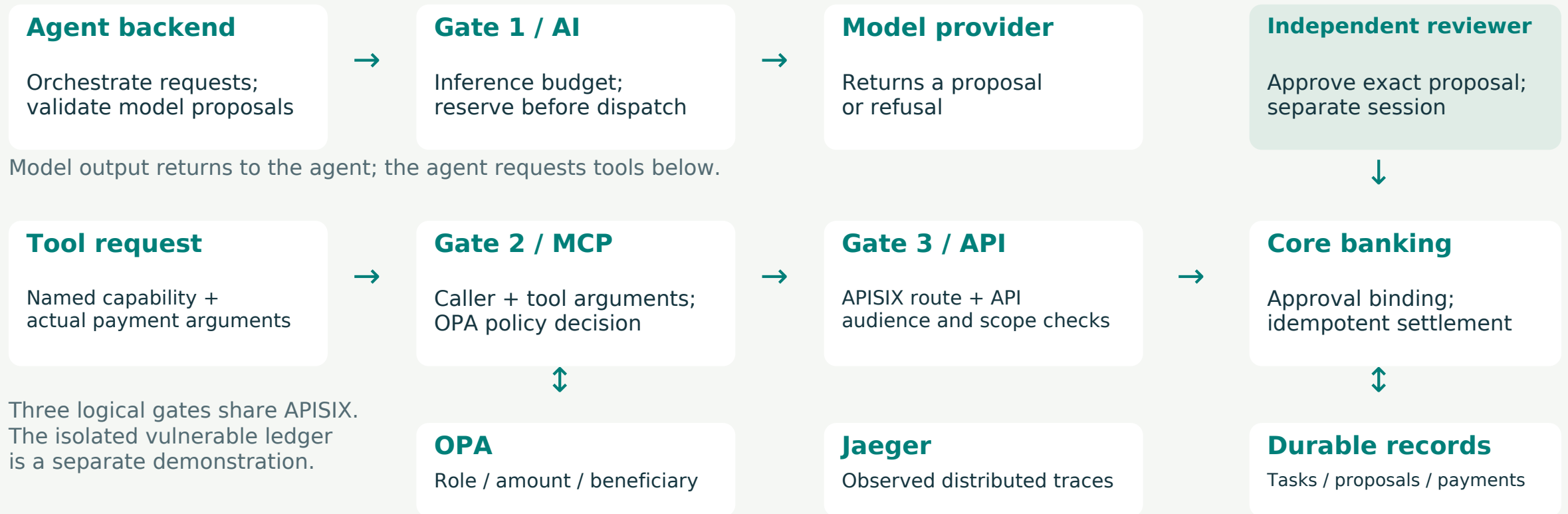
HTTP 200 may carry a tool error. Read the MCP decision inside the response.

Three gateways, three different decisions

Boundary	Traffic	Decision in W4
API / Gate 3	HTTP business requests	Correct audience, scope and business authority?
AI / Gate 1	Model inference	Does projected usage fit the allowance?
MCP / Gate 2	Tool discovery and invocation	May this caller use this tool with these arguments?

A decision at one boundary does not replace checks on another route.

Flo Bank: Triple-Gate architecture



Agent orchestration connects model output to tools; business authority stays explicit.

Presenter lab and QR observers

LOCAL PRESENTER

Runs fixed scenarios against protected services and a separate replay ledger.

QR AUDIENCE

Reads curated recorded evidence. No approval or payment execution.

SHARED METHOD

Predict the decision; inspect caller, arguments, response and effect.

The observer recording does not synchronize live with the presenter ledger.

Join the Incident Room



OPEN ON YOUR PHONE

<https://w4.ravirai.in/workshop-4>

AUDIENCE ACCESS CODE

Provided live by facilitator

Recorded evidence only · no payment execution

Access closes: 12:00 IST · 10 October 2026

Scan → enter the event code → select a recorded run → inspect the evidence.

The day the agent broke the bank

Implementing Triple-Gate Architecture & A2A Security for Autonomous AI Workloads

Start the 135-minute lab clock / Become Flo Bank's response team

₹90 lakh

900,000,000 paise. One payment. API 200. Valid credentials.

Opening incident: isolated vulnerable ledger; protected-ledger delta stays zero.

Your assignment: repair and prove the bank still works

INVESTIGATE

Find where untrusted case text became payment authority.

CONTAIN

Test inference, tool, identity, approval and delegation boundaries.

RESTORE

Block the attacks and prove one legitimate, independently approved settlement.

Every chapter: predict → run → inspect → change → retest.

The incident-response clock / first half

Time	Chapter	Pair evidence
0-8	The bank has paid	Opening prediction
8-20	Follow the money	Attack chain + both ledgers
20-33	Contain inference	Budget denial vs tool policy
33-53	Control capabilities	Policy repair + ₹250 payment
53-60	Try the direct API	Audience / scope denials
60-67	Break + checkpoint recovery	Ready local lab

Follow the worksheet; record the actual evidence from your run.

The incident-response clock / second half

Time	Chapter	Pair evidence
67-85	Restrict identity	Entitled token exchange
85-103	Approve the transaction	Independent review + one effect
103-119	Secure delegation	Task access + payment binding
119-130	Prove the repair	Blocked attacks + valid payment
130-135	Incident review	Control owners + next work

Follow the worksheet; record the actual evidence from your run.

Follow the money across the handoff

01

Ticket

Untrusted
instructions



02

NegotiatorBot

Recorded
settlement
proposal



03

PaymentsAgent

Delegated
execution request



04

Vulnerable bank

Valid request;
harmful payment

Mark the point where information was treated as authority.

Replay one incident; inspect two ledgers

Ledger	Expected delta	Interpretation
Isolated vulnerable ledger	−900,000,000 paise; +1 payment	Recorded harmful proposal executed
Protected banking ledger	0 paise; 0 new payments	Separate protected state unchanged

The replay establishes this fixed request's result, not a live model compromise.

The Triple-Gate model

GATE 1

Inference access and budgets: may this model request be dispatched?

GATE 2

MCP capability policy: may this identity call this tool with these arguments?

GATE 3

API access and banking rules: is this exact business operation authorized?

Independent review and delegation binding extend protection across the business process.

Gate 1: stop dispatch when the budget is exhausted

PREDICT

Would a model budget denial also block an independent direct tool request?

RUN

Execute the exhausted-headroom scenario. Inspect HTTP 429 before provider dispatch.

COMPARE

Run the independent Gate 2 scenario and inspect its own response.

Inference limits govern inference dispatch. Tool authorization remains independent.

Why 140 / 100,000 can still produce a denial

Budget component	Illustrative run	Interpretation
Already used	140 tokens	Existing usage is below the limit
Remaining headroom	99,860 tokens	Available before the next request
Incoming request	Oversized prompt + 512 output	Projected total exceeds the allowance

The error omits incoming estimates. 140 itself did not exceed 100,000.

Gate 2: isolate the reason for denial

Request	Expected result	Ledger
25,000 paise to prohibited beneficiary	Prohibited-beneficiary denial	No change
900,000,000 paise to permitted vendor	Transfer-ceiling denial	No change
25,000 paise to vendor-alpha	Allowed after local repair	–25,000; +1 payment

Change one relevant dimension so the evidence identifies the control.

Inspect the actual MCP payment payload

JSON-RPC / SANITIZED REQUEST BODY

```
{"jsonrpc": "2.0", "id": "<run-id>",  
  "method": "tools/call",  
  "params": {"name": "create_payment", "arguments": {  
    "account_id": "acc-101",  
    "beneficiary": "vendor-alpha",  
    "amount": 9000000000, "currency": "INR"  
  }}}
```

Evidence drawer → Tool policy event → arguments.params.arguments

Exercise: repair the prepared local policy

The initial checkpoint also blocks the legitimate vendor-alpha payment.

TERMINAL / FROM REPOSITORY ROOT

```
cp workshops/w4/checkpoints/initial/policy.rego \  
  spikes/spike3_opa/policy.rego  
docker compose restart opa  
  
# Remove only vendor-alpha from the prepared prohibited list.  
# Keep fraud-account-66 blocked, restart OPA, then retest.
```

Work on the pair's local instance and save before/after service results.

Retest the repair against both attack and business paths

Attacker remains blocked. Excessive amount remains blocked. ₹250 vendor payment succeeds.

TERMINAL / FROM REPOSITORY ROOT

```
# Completed checkpoint if a pair needs recovery:  
cp workshops/w4/checkpoints/completed/policy.rego \  
    spikes/spike3_opa/policy.rego  
docker compose restart opa
```

A policy repair succeeds when legitimate work is restored and attacks remain denied.

Gate 3: the attacker changes routes

Attempt	Expected status	Missing authority
Use an MCP-audience token at the API	401	Correct API audience
Use a read-only token to write a payment	403	Payment-write scope

The direct API path must enforce its own audience and scope checks.

Break / checkpoint recovery

Can the payment agent approve its own transaction?

Seven-minute break. Facilitator restores stalled local checkpoints.

Identity must narrow at the next boundary

01

Principal

Validated subject +
role



02

Exchange

Check requested
entitlement



03

API token

Correct audience +
limited scopes



04

Banking API

Verify on every
request

A valid signature proves origin; audience and scope constrain intended use.

Exercise: request only an entitled scope

The initial viewer request asks for payment-write authority.

TERMINAL / FROM REPOSITORY ROOT

```
.venv/bin/python workshops/w4/exercise_exchange.py initial  
  
# In checkpoints/initial/identity.json, change requested_scope  
# from api:payments:write to api:accounts:read, then rerun.  
  
.venv/bin/python workshops/w4/exercise_exchange.py completed
```

Original request: 403. Corrected/completed read-scope request: 200.

Explain the identity evidence

Scenario	Expected response	Save
Viewer requests payment-write scope	403 entitlement denial	Requested scope + decision
Viewer requests account-read scope	200 permitted exchange	Sanitized audience + scopes
MCP token sent to banking API	401 audience denial	Boundary response
Read token attempts payment	403 scope denial	Zero ledger change

Keep issued tokens and signing keys out of exported evidence.

Approval attaches to one exact transaction

REVIEW THE VALUES

Source account
Amount in paise
Currency
Beneficiary

REVIEW THE CONTEXT

Proposal ID
Task ID
Expiry
Independent reviewer

EXPECTED RESULT

₹1,500 / 150,000
paise
One approved
settlement
One actual payment
ID

Create the legitimate-delegation proposal immediately before review.

Retrieve the local reviewer password

Run privately on the local lab host. Never project the result.

TERMINAL / FROM REPOSITORY ROOT

```
docker compose exec -T api printenv W4_REVIEWER_PASSWORD
```

Separate browser session + reviewer login + exact proposal review.

Use an independent reviewer session

01

Requester

Run legitimate delegation



02

Reviewer

Separate private browser



03

Authorize

Reviewer password + exact review



04

Decide

Approve or reject

Selecting “Independent reviewer” alone grants no authority.

Attempt self approval and transaction tampering

Attempt	Expected result	Meaning
Payment agent approves itself	403	Requester/delegation rule enforced
Independent exact review	200	Proposal approved
Execute with changed arguments	400	Approval does not cover the change
Execute exact approved request	200	Authorized settlement can proceed

Inspect each boundary result and the actual ledger effect.

One effect survives a retry

EXECUTE

Use the approved exact arguments and stable financial key.

RETRY

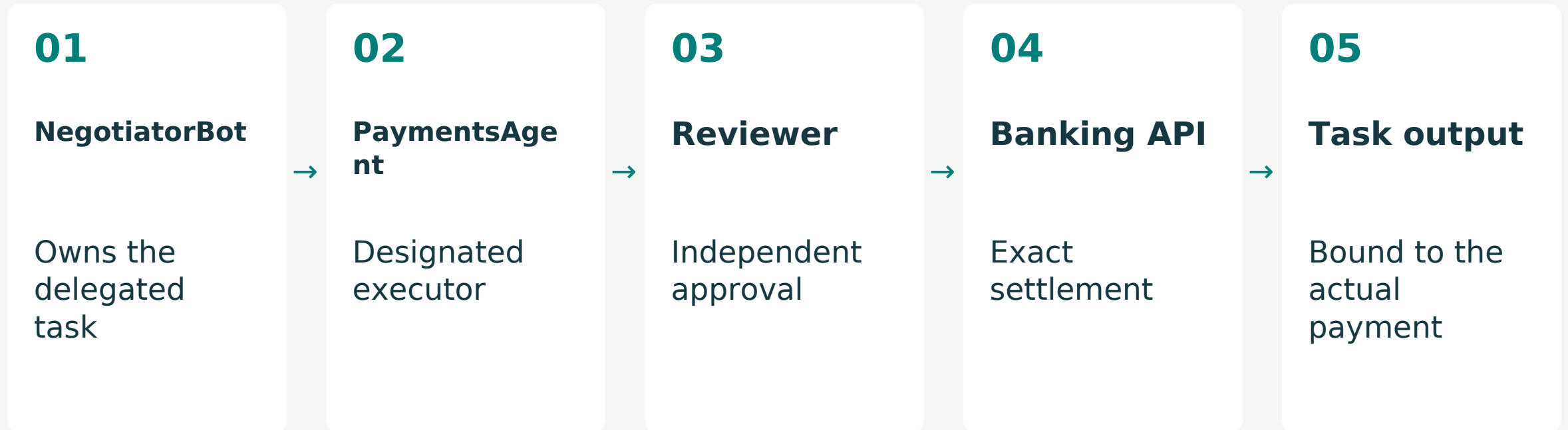
Return the existing result under the same key.

PROVE

Balance delta:
–150,000 paise
Payment count delta:
+1
Same payment identity

For an uncertain response, select the original run and reconcile.

A second agent creates a second boundary



Delegation needs explicit permissions for read, execute, approve and complete.

Test access to the delegated task

Attempt	Expected result	Evidence
Foreign principal reads task	403	Task-access denial
Non-executor completes task	403	Completion denial
Bind payment to mismatched task	400	Binding validation failure
Valid bound task completion	200	Task output has actual payment ID

A valid agent identity does not grant access to every task.

Bind completion to a business fact

MATCH

Source, amount, currency, beneficiary and proposal context.

LINK

Task output payment ID equals the actual settled ledger payment ID.

REJECT

A plausible success message or unrelated payment is insufficient.

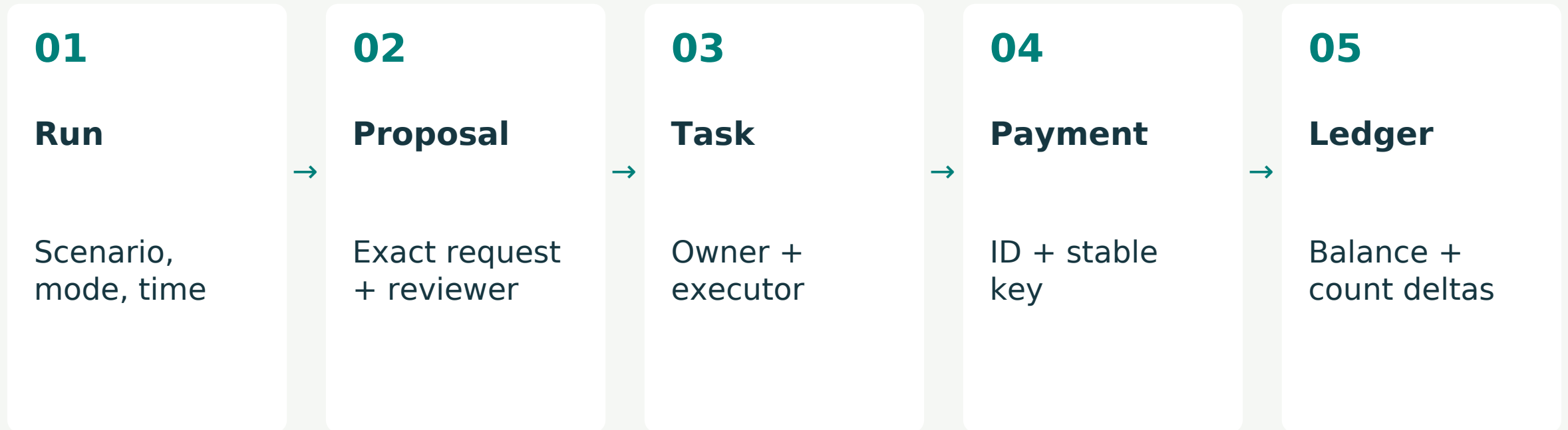
Task completion is proven by its relationship to the real settlement.

Prove the repaired system in both directions

Control	Attack result	Legitimate result
Inference	Budget exhaustion blocks dispatch	Bounded access remains possible
Tool policy	Beneficiary / ceiling denials	₹250 vendor payment
Identity	Wrong audience / escalation denied	Entitled read-scope exchange
Approval	Self review / tampering denied	Exact ₹1,500 settlement
Delegation	Foreign access / mismatch denied	Payment bound to task

Use your observed service results; keep unresolved outcomes visible.

Reconstruct the incident from familiar records



Correlate observed spans, or explicitly label the trace incomplete.

Incident review: what did your first vote miss?

EXPLAIN A DENIAL

Name the caller, arguments, boundary response and observed ledger delta.

PROVE A PAYMENT

Link independent review, proposal, task, payment and one financial effect.

ASSIGN OWNERS

Inference, tool policy, identity, approval, audit and incident operations.

Before production: managed identity, resilient state, audit operations and conformance.

Restore useful work under explicit authority

The final evidence: blocked attacks alongside a correctly approved and bound payment.

Capabilities → Governance → Durability → Incident-tested boundaries

Presenter preparation & source guide

PREPARE

Local w4 per pair.
Independent reviewer session. Optional isolated presenter sandbox.

CHECK

workshop status +
verify w4
Incident Room
readiness
Completed local
checkpoints

RECOVER

Timebox stalls to two minutes. Export evidence. Reconcile original runs.

Follow the W4 answer key for secret configuration, isolation and rehearsal setup.